

EU Compliance Master Report

ประเด็นสำคัญที่ต้องปรับปรุงและเตรียมความพร้อมเพื่อให้ DavinTrade App ให้บริการแก่ผู้ใช้ใน EU ได้อย่างถูกต้องตามกฎหมาย

1. บทสรุปสำหรับผู้บริหารและทีมงาน (Executive Summary)

ตามที่สหภาพยุโรปได้ประกาศใช้ Digital Omnibus on AI (Regulation (EU) 2026/1744) ซึ่งมีผลบังคับใช้เมื่อวันที่ 27 กรกฎาคม 2026 สารสำคัญคือการขยายเวลาบังคับใช้ข้อกำหนดสำหรับระบบ AI ที่มีความเสี่ยงสูง (High-Risk AI Systems) ออกไปเป็นวันที่ 2 ธันวาคม 2027 และ 2 สิงหาคม 2028 ตามลำดับ

อย่างไรก็ตาม มาตรา 50 ว่าด้วยหน้าที่ด้านความโปร่งใส (Transparency Obligations) ไม่มีการเลื่อนกำหนด และมีผลบังคับใช้แล้วตั้งแต่วันที่ 2 สิงหาคม 2026 โดยมีข้อยกเว้นผ่อนผันเฉพาะข้อกำหนดเรื่องการทำเครื่องหมายเนื้อหาที่เครื่องอ่านได้ (มาตรา 50(2)) สำหรับระบบที่อยู่ในตลาดก่อน 2 ส.ค. 2026 ให้ดำเนินการให้ครบถ้วนภายใน 2 ธันวาคม 2026

⚠ ขอบเขตการบังคับใช้นอกอาณาเขต (Extraterritorial Scope) & อัตราโทษปรับ

กฎหมาย EU AI Act และ GDPR บังคับใช้กับผู้ให้บริการซอฟต์แวร์นอกสหภาพยุโรป หากระบบหรือผลลัพธ์ของระบบ (Outputs) ไปถึงผู้ใช้ปลายทางที่พำนักอยู่ใน 27 ประเทศสมาชิก EU โดยไม่คำนึงว่าบริษัทจะจดทะเบียนที่ใดในโลก การฝ่าฝืนมาตรา 50 มีโทษปรับสูงสุด 15 ล้านยูโร หรือ 3% ของรายได้รวมทั่วโลก (สำหรับสตาร์ทอัพและ SME ใช้จำนวนที่ต่ำกว่า)

สถานะของ DavinTrade: แอปพลิเคชัน DavinTrade จัดอยู่ในกลุ่ม Limited Risk AI System (ไม่ใช่ High-Risk) แต่เนื่องจากมีฟีเจอร์ Conversational AI Analyst (Stack D), Automated Market Comment Narrative (Stack E), Customer Support Web Chat (Phase 14) และระบบแจ้งเตือนการเทรด จึงตกอยู่ภายใต้ มาตรา 50 (Transparency) พร้อมทั้งต้องสอดคล้องกับกฎหมายคุ้มครองข้อมูลส่วนบุคคล (GDPR) และระเบียบการเงินการคุ้มครองผู้บริโภค (MiFID II / ESMA)

2. ตารางสรุปภาพรวมความพร้อมและผลกระทบ (Compliance Matrix)

กรอบกฎหมาย EU	ส่วนประกอบใน DavinTrade	ประเด็นความสอดคล้อง / สิ่งที่ต้องปรับปรุง	ระดับความสำคัญ
EU AI Act (Art. 50(1)) การเปิดเผยตัวตน AI	- Stack D (AIAnalystPanel) - Phase 14 (Web Chat Bot)	ติดป้ายแจ้งเตือนผู้ใช้ตั้งแต่ข้อความแรกว่าเป็น AI และมี Persistent Badge ห้ามแอบอ้างเป็นนักวิเคราะห์มนุษย์	เร่งด่วนที่สุด
EU AI Act (Art. 50(2)) เครื่องหมายที่เครื่องอ่านได้	/api/ai/chat/stream (SSE) - Part 24 Chart PNG Images	ฝัง Machine-Readable Metadata (is_ai_generated: true, model, timestamp) ใน JSON payload, SSE และ Exif ของรูปภาพ	เส้นตาย 2 ร.ค. 26
EU AI Act (Art. 50(4/5)) ป้ายกำกับคำแนะนำ & Feeds	- Stack E (Market Comments) - TradeSetupCard (Entry/TP/SL)	ติดป้ายชัดเจนว่าเป็น "AI-Generated Signal" และมี Disclaimer กำกับว่าไม่ใช่คำแนะนำการลงทุนส่วนบุคคล	เร่งด่วนที่สุด
EU GDPR (Art. 17) สิทธิการลบข้อมูล	/settings/account - ธง F21 (Deletion Gap)	สร้าง Background Worker ทำการ Hard-Delete / Anonymize ข้อมูลจริงหลังจากหมด 24h grace period (ปิดช่องโหว่ F21)	สำคัญสูง
ePrivacy & GDPR Cookie Consent	- app/layout.tsx - Tracking & Analytics	เพิ่ม Cookie Consent Banner แบบ Opt-in ที่แยกหมวดหมู่ Necessary, Functional และ Analytics	สำคัญสูง
GDPR (Art. 13/14) Prompt Privacy	- Stack D Context Layer - Gemini / Claude Router	ติดตั้ง PII Sanitization เพื่อตัดข้อมูลส่วนบุคคลก่อนส่งเข้า LLM และให้สิทธิผู้ใช้ Opt-out จากการใช้ข้อมูลเทรนโมเดล	สำคัญสูง
MiFID II & ESMA คำเตือนความเสี่ยงการเงิน	/disclaimer /pricing, /terminal	ระบุสถานะ "Execution-Only Software" และใส่คำเตือนความเสี่ยงอนุพันธ์ CFD/Forex ตามมาตรฐาน ESMA	สำคัญสูง
EU Consumer Rights สิทธิยกเลิก 14 วัน	/checkout (Stripe / dLocal)	เพิ่ม Checkbox สละสิทธิการถอนตัว 14 วัน เพื่อขอเข้าใช้งานระบบ SaaS ทันที (Right of Withdrawal Waiver)	ปานกลาง
PSD2 (SCA) & VAT ความปลอดภัยการชำระเงิน	- Stripe & dLocal Webhooks - Invoicing Service	บังคับใช้ 3D Secure 2 (3DS2) สำหรับบัตรธนาคารในยุโรป และคำนวณภาษีมูลค่าเพิ่มตามประเทศสมาชิก (EU VAT OSS)	ปานกลาง

3. การปรับปรุงทางเทคนิคตาม EU AI Act — มาตรา 50 (Transparency)

3.1 การแจ้งเตือนการโต้ตอบกับ AI (Article 50(1) — AI Chatbot Disclosure)

ข้อกำหนด: ผู้ให้บริการระบบ AI ที่มีปฏิสัมพันธ์กับบุคคลธรรมดาโดยตรง ต้องออกแบบระบบให้ผู้ใช้รับรู้ได้ในทันทีที่กำลังสื่อสารกับปัญญาประดิษฐ์

- **Stack D (Conversational AI Analyst — Phase 12):**

- ในคอมโพเนนต์ AIAlystPanel.tsx บนหน้าจอ /terminal ต้องมีป้ายกำกับถาวร (Persistent Badge) เช่น

 **DavinTrade AI Analyst** ตลอดเวลา

- ในข้อความทักทายแรกของทุกเซสชัน (System Greeting) ต้องระบุข้อความชัดเจน: *"Hello! I am DavinTrade AI, an algorithmic co-pilot analyzing XAUUSD market structures. How can I assist your technical analysis today?"*

- ในช่องเลือกโมเดล (Model Selector) เช่น Gemini 3.6 Flash / Pro หรือ Claude 3.5 Sonnet ต้องระบุชัดเจนว่าเป็น Third-party Foundation Models

- **Phase 14 (Web Chat / Support Bot บน Contabo):**

- บอทดตอบคำถามลูกค้าต้องแนะนำตัวว่าเป็น AI Assistant และต้องมีปุ่ม **"Transfer to Human Agent"** หรือ Fallback ส่งเรื่องเข้า Support Ticket หากผู้ใช้ต้องการสนทนากับมนุษย์

3.2 การทำเครื่องหมายเนื้อหาที่เครื่องอ่านได้ (Article 50(2) — Machine-Readable Marking)

ข้อกำหนด: ผลลัพธ์ที่เป็นข้อความ รูปภาพ หรือข้อมูลที่สร้างจาก AI ต้องมี Metadata ในรูปแบบที่ระบบคอมพิวเตอร์สามารถตรวจจับได้ (Detectable & Machine-Readable)

- **API & Server-Sent Events (SSE) Stream:**

ทุก Chunk และ Response Payload ของ /api/ai/chat/stream และ /api/ai/chat จะต้องแนบ Data Schema บ่งชี้ความเป็น AI:

```
{ "event": "message_chunk", "data": { "text": "Market structure indicates potential liquidity sweep at...", "meta": { "is_ai_generated": true, "generator": "DavinTrade-Multimodal-Router", "model_version": "gemini-3.6-flash", "timestamp_utc": "2026-08-26T07:30:00Z" } } }
```

- **Part 24 Chart PNG Render Images:**

รูปภาพกราฟ 3-Panel ที่ส่งเข้าวิเคราะห์หรือส่งออกไปยังผู้ใช้ (mtf_render_xauusd.png) ควรกำหนดให้ Python renderer.py เขียนบันทึก Exif Tag / XMP Metadata หรือฝังเครื่องหมายดิจิทัลยืนยันว่าเป็น Technical Chart ที่เรนเดอร์โดยโปรแกรมคอมพิวเตอร์ และตรวจสอบว่ากระบวนการอัปโหลดผ่าน Vercel Blob ไม่ทำการตัด (strip) Metadata ดังกล่าวออก

3.3 การติดป้ายกำกับคำแนะนำและข้อคิดเห็นทางการเงิน (Article 50(4) & 50(5) — Output Labeling)

ข้อกำหนด: ข้อมูลหรือสัญญาณเชิงปริมาณที่เผยแพร่สู่สาธารณะหรือผู้ใช้งาน จะต้องติดป้ายเปิดเผยเพื่อป้องกันการเข้าใจผิดว่าเป็นข้อคิดเห็นหรือคำแนะนำการลงทุนส่วนบุคคลจากมนุษย์

- **Stack E Market Comments (Phase 13):** ในหน้าจอ MarketCommentsFeed ที่ดึงข้อมูลจาก PostgreSQL Trigger (short_comment, call_action) ต้องมีไอคอนระบุว่า **Algorithmic Comment** กำกับทุกแถว

- **TradeSetupCard (Phase 12-5):** การ์ดแสดงจุด Entry, Take Profit (TP), Stop Loss (SL) และ Risk/Reward Ratio จะต้องมีความกำกับท้ายการ์ดเสมอ:

"Automated Quantitative Setup — Generated algorithmically based on centroid regression & SSA models. Not financial advice."

4. การปฏิบัติตามกฎหมายคุ้มครองข้อมูลส่วนบุคคล (EU GDPR)

4.1 การปิดช่องโหว่การลบข้อมูลบัญชีถาวร (Right to Erasure — sv F21)

ในระบบปัจจุบัน บัญชีใน DECISION-LOG.md มีธง **F21 (24h Account-Deletion GDPR gap)** ค้างสถานะ OPEN เนื่องจากหน้า /settings/account มีการส่งคำขอไปยัง /api/user/account/deletion-request และ deletion-confirm แต่ใน Backend ยังมีเฉพาะ console.log และยังไม่มี Background Worker ที่ทำการลบข้อมูลจริง

🔧 แผนการปิดธง F21 สำหรับทีมพัฒนา:

1. สร้าง Cron Job AccountDeletionScheduler ใน operation-service ให้ตรวจจับบัญชีที่พ้น 24-hour grace period
2. ทำการ Hard-Delete ข้อมูลที่ไม่มีภาระทางกฎหมาย (Sessions, Login History, Drawings, DrawingAlerts, Notification Preferences)
3. ทำการ Anonymize ข้อมูลที่จำเป็นต้องเก็บตามกฎหมายบัญชี/ภาษี (User ID ในตาราง Payments / Invoices ให้เปลี่ยนเป็นค่า Anonymized Hash)

4.2 การจัดการความยินยอมคุกกี้ (Cookie Consent Management)

ต้องติดตั้ง **Cookie Consent Banner** บน app/layout.tsx สำหรับผู้ใช้งานจากกลุ่มประเทศ EU/EEA โดยมีสวิตช์เปิด-ปิดความยินยอมแยก 3 ระดับ: (1) *Strictly Necessary*, (2) *Functional / Preferences*, และ (3) *Analytics & Telemetry* โดยห้ามโหลดสคริปต์ Tracking ใดๆ ก่อนได้รับความยินยอมแบบ Explicit Opt-in

4.3 การส่งข้อมูลเข้า AI และความปลอดภัยของข้อมูล Prompt (Prompt Sanitization)

ใน app/(marketing)/privacy/page.tsx ระบุว่านำข้อมูลไปปรับปรุง Davin AI ซึ่งตาม GDPR ผู้ใช้ใน EU มีสิทธิ์เลือกที่จะยินยอมให้นำข้อมูลไปเทรนหรือไม่ (Opt-out Right) นอกจากนี้ใน **Phase 12-3 (Context Assembly Layer)** ต้องติดตั้ง **PII Sanitizer Filter** เพื่อตัดข้อมูลส่วนบุคคล (เช่น ชื่อผู้ใช้, อีเมล, หมายเลขบัญชี, เลข IP) ออกจาก Payload ก่อนยิง API ไปยัง Google Gemini หรือ Anthropic ในประเทศที่สาม

5. กฎหมายการเงินและการคุ้มครองผู้บริโภค (MiFID II, ESMA & Consumer Rights)

5.1 การกำหนดขอบเขต "เครื่องมือวิเคราะห์เชิงปริมาณ" เพื่อให้เข้าข่าย "คำแนะนำการลงทุน"

ภายใต้กฎหมาย MiFID II (Markets in Financial Instruments Directive) ของ EU การให้คำแนะนำจะจูงจูงซื้อขายสินทรัพย์แก่บุคคลโดยไม่มีใบอนุญาตประกอบธุรกิจหลักทรัพย์ถือเป็นความผิดร้ายแรง ดังนั้น DavinTrade ต้องตอกย้ำสถานะทางกฎหมายในทุกจุด:

- **Legal Status:** ต้องระบุชัดเจนว่าเป็น "Execution-Only Technical Analysis Software & Algorithmic Tool"
- **Risk Warnings:** ปรับปรุง app/(marketing)/disclaimer/page.tsx, /pricing, และ /checkout ให้มีคำเตือนความเสี่ยงมาตรฐานของ ESMA สำหรับผลิตภัณฑ์อนุพันธ์ CFD และ Gold Margin Trading เช่น:

"CFDs and leveraged financial instruments are complex products with a high risk of losing money rapidly due to leverage. You should consider whether you understand how these products work and whether you can afford to take the high risk of losing your money. DavinTrade does not provide personalized investment advice."

5.2 สิทธิการบอกเลิกสัญญาภายใน 14 วัน (EU 14-Day Statutory Right of Withdrawal)

ตามระเบียบ EU Consumer Rights Directive ผู้บริโภคในยุโรปมีสิทธิยกเลิกการสั่งซื้อสินค้าดิจิทัลและขอเงินคืนได้ภายใน 14 วัน เว้นแต่ผู้บริโภคจะให้ความยินยอมโดยชัดแจ้งในการเริ่มใช้บริการทันทีและยอมรับการสละสิทธิถอนตัวดังกล่าว

สิ่งที่ต้องทำบนหน้า Checkout (Phase 9-6): เพิ่ม Checkbox บังคับติ๊กก่อนชำระเงินสำหรับลูกค้าในกลุ่มประเทศ EU:

☒ "I hereby request immediate access to the DavinTrade PRO subscription services upon completion of payment, and I acknowledge that I thereby lose my statutory 14-day right of withdrawal under EU consumer protection regulations."

5.3 ความปลอดภัยในการชำระเงิน (PSD2 / 3DS2) และภาษีมูลค่าเพิ่ม (EU VAT OSS)

- **Strong Customer Authentication (SCA):** ตรวจสอบว่าโมดูล Stripe Webhook (Session 4A-13) และ dLocal Payment Methods (Session 4A-16) มีการบังคับใช้ 3D Secure 2 (3DS2) สำหรับบัตรที่ออกใน EU เพื่อป้องกันปัญหา Payment Decline
- **EU VAT Calculation:** ปรับระบบ Invoicing ให้คำนวณและแสดงอัตราภาษีมูลค่าเพิ่ม (VAT) ตามประเทศสมาชิก EU ของผู้ซื้อ (หรือระบบ Reverse Charge ในกรณีลูกค้าองค์กร B2B ที่กรอกเลขนิติบุคคล EU VAT ID ที่ถูกต้อง)

6. แผนที่การนำข้อกำหนด EU ไปผูกกับ Master Roadmap (Phases 7–15)

เพื่อให้ทีมพัฒนาสามารถนำข้อกำหนดทั้งหมดไปปฏิบัติได้ทันทีโดยไม่กระทบต่อโครงสร้างการทำงานเดิม ข้อกำหนดทั้งหมดถูกจัดสรรลงใน Session ต่างๆ ของ Master Roadmap ดังนี้:

Phase / Session	ชื่องานใน Roadmap	งานที่ต้องปฏิบัติเพื่อสอดคล้องกับ EU	สถานะ
Phase 9-0 / 9-2	Frontend Swap & Marketing Legal Pages	- อัปเดต disclaimer/page.tsx และ terms/page.tsx รองรับ EU AI Act & ESMA - ติดตั้ง Cookie Consent Banner ใน app/layout.tsx	Phase 9
Phase 9-5	Settings Surface	- จัดการหน้า /settings/privacy ให้มีฟังก์ชัน Opt-out จาก AI Training - เตรียม UI เชื่อมต่อคำขอลบข้อมูลบัญชี	Phase 9
Phase 9-6	Payments Flow	- เพิ่ม Checkbox สละสิทธิคืนเงิน 14 วัน (EU Withdrawal Waiver) - ปรับแต่ง Stripe & dLocal ให้รองรับ EU VAT OSS & 3DS2	Phase 9
Phase 11-2	Header Forwarding	ปรับปรุง forwardedRequestContext() ให้ส่งผ่าน GeoIP Country Header เพื่อให้ระบบตรวจจับผู้ใช้ใน EU ได้อย่างแม่นยำ	Phase 11
Phase 12-0 / 12-3 / 12-5	Stack D: AI Analyst & Dynamic Cards	- ติดตั้ง PII Sanitizer ใน Context Assembly Layer ก่อนส่ง Prompt - ฝัง Machine-Readable Metadata ใน SSE Stream (Art. 50(2)) - ติดป้าย AI Badge และ Non-Advisory Disclaimer บน TradeSetupCard.tsx	Stack D
Phase 13-0 / 13-3	Stack E: Market Comments	ติดป้ายกำกับ Algorithmic / Machine-Generated ใน Market Comments Feed	Stack E
Phase 14-0 / 14-2	Web Chat Stack	เพิ่ม Initial Disclosure ในบอทแชทพอร์ต และทำปุ่ม Transfer to Human Agent	Phase 14
Phase 8A / F21	Decommission & GDPR Closure	ปิดธง F21 โดยสร้าง Background Worker ลบข้อมูลบัญชีถาวรหลังพ้น 24 ชม.	Decom

7. สรุปคำแนะนำและรายการตรวจสอบสำหรับผู้บริหาร (Executive Checklist)

📋 สรุปจุดโฟกัส 3 ลำดับแรก (Top 3 Immediate Priorities):

- ด้านกฎหมาย & ข้อความระบุตัวตน (Legal & Branding):** ตรวจสอบว่าทุกหน้าต่างแชน (Stack D / Phase 14) มีป้ายบอกสถานะ AI ชัดเจน และมี Disclaimer กำกับได้ Trade Setup Cards ทุกใบ
- ด้านวิศวกรรมข้อมูล & AI (Engineering & Data):** ออกแบบ API Response และ SSE Stream ให้มี Metadata บ่งบอกว่าเป็น AI-Generated ตั้งแต่เริ่มพัฒนา Phase 12 เพื่อให้เสร็จทันเส้นตายพ่นผัน 2 ธ.ค. 2026
- ด้านความเป็นส่วนตัว (Privacy & GDPR):** ปิดช่องโหว่ธง F21 โดยการสร้าง Account Deletion Worker ให้ลบข้อมูลจริง และติดตั้ง Cookie Consent Banner ก่อนเปิดตัวอย่างเป็นทางการ

เอกสารฉบับนี้จัดทำขึ้นสำหรับการวางแผนทางวิศวกรรมและสถาปัตยกรรมซอฟต์แวร์ของโครงการ DavinTrade เพื่อใช้ประกอบการพิจารณาของทีมกฎหมายและผู้บริหาร